

KRİPTOGRAFİ KAVRAMLARI

[Kaynak](#)

İÇERİK

1. Cryptography: Temel Kavramlar ve Veri Güvenliğinin Matematiksel Zırhı
2. Symmetric Encryption: Veriyi Simetrik Anahtarlarla Koruma
3. Asymmetric Encryption: Güvenli Anahtar Dağıtımı ve Sertifika Mimarisi

Cryptography: Temel Kavramlar ve Veri Güvenliğinin Matematiksel Zırhı

Dijital dünyada verinin bir noktadan diğerine iletilmesi, fiziksel bir kurye teslimatından ziyade, bir notun onlarca yabancıdan elinden geçerek hedefe ulaşmasına benzer. İnternet üzerindeki her veri paketi; yönlendiriciler (routers), sunucular ve aracı sistemler üzerinden sekerken potansiyel birer **Interception** (Araya girme/dinleme) hedefidir. Tarayıcınızdaki o küçük asma kilit simgesi, sadece görsel bir güven telkini değil, arkasında devasa bir matematiksel disiplinin çalıştığının kanıtıdır.

Siber Güvenliğin Temeli: CIA Triad ve Kriptografi İlişkisi

Siber güvenliğin kutsal üçlüsü olan **CIA Triad** (Confidentiality, Integrity, Availability), bir sistemin güvenliğini ölçmek için kullanılan temel metriktir. Kriptografi, bu üçlünden özellikle ilk ikisini (Gizlilik ve Bütünlük) sağlamak için kullanılan en kritik araçtır:

- **Confidentiality (Gizlilik):** Verinin sadece yetkili taraflar tarafından okunabilmesini sağlar. Kriptografi, veriyi **Scrambling** (Karıştırma/Anlamsızlaştırma) işlemiyle yetkisiz gözler için okunamaz hale getirir.
- **Integrity (Bütünlük):** Verinin iletim sırasında değiştirilmediğini garanti eder. Eğer bir saldırgan veriyi modifiye ederse, kriptografik kontroller (hashing vb.) bu değişikliği anında tespit etmemizi sağlar.
- **Availability (Erişilebilirliği Tehdit Eden Durumlar):** Doğrudan bir kriptografi konusu olmasa da, verinin şifrelenmesi veya dijital imzalanması, verinin manipüle edilip sistemlerin işleyişini bozmasını engelleyerek dolaylı yoldan sürekliliğe hizmet eder.

Senaryo Analizi: Veri İletimindeki Riskler

Bir tıbbi klinik işlettiğinizi ve hasta kayıtlarını (isim, teşhis, tedavi geçmişi) internet üzerinden sigorta şirketlerine veya uzman doktorlara gönderdiğiniz varsayalım. Bu veriler **Plaintext** (Açık metin - herkes tarafından okunabilir format) olarak gönderildiğinde karşılaşılabilecek temel tehditler şunlardır:

1. **Disclosure (İfşa):** Verinin yoldaki herhangi bir sistem yöneticisi veya saldırgan tarafından okunması.
2. **Alteration (Değiştirme):** Bir saldırganın tıbbi kayıtları değiştirerek yanlış tedaviye veya sigorta dolandırıcılığına yol açması.
3. **Destruction (Yok Etme):** Verinin hedefe hiç ulaşmamasının sağlanması.

Kriptografi (Cryptography), bu noktada devreye girerek matematiksel kurallar ve **Secret Keys** (Gizli Anahtarlar) kullanımıyla bilgiyi anlamsız bir veri yığınına dönüştürür. Bu süreçte **Encryption** (Şifreleme), bu karmaşık yapıyı tekrar okunabilir hale getirme sürecine ise **Decryption** (Şifre Çözme) denir.

Kriptografinin Teknik Mantığı

Kriptografi sadece "şifre koymak" değildir; verinin güvenli bir şekilde işlenmesini sağlayan bir **Applied Mathematics** (Uygulamalı Matematik) dalıdır. Süreç temel olarak şu bileşenlerden oluşur:

- **Algorithm (Algoritma):** Veriyi dönüştürmek için kullanılan matematiksel formül veya mantık dizisidir (Örn: AES, RSA).
- **Key (Anahtar):** Algoritmanın çıktısını benzersiz kılan parametredir. Aynı algoritma kullanılsa bile, anahtar farklı olduğunda üretilen şifreli metin tamamen farklı olur.
- **Ciphertext (Şifreli Metin):** Algoritma ve anahtar kullanılarak dönüştürülmüş, orijinal veriyi temsil eden ancak anlamlandırılmayan veri formudur.

ÖNEMLİ: Modern kriptografide "algoritmanın gizli tutulması" bir güvenlik yöntemi olarak kabul edilmez (**Security through obscurity** - Gizlilik yoluyla güvenlik hatası). Güvenlik, algoritmanın herkes tarafından bilinmesine rağmen, **Key** (Anahtar) olmadan şifrenin kırılmayacağı gerçeğine (Kerckhoffs İlkesi) dayanır.

Neden Bu Temelleri Öğreniyoruz?

Bir siber güvenlik uzmanı olarak sadece araçları (Tools) kullanmak yeterli değildir. Bir saldırı sırasında ele geçirdiğiniz verinin nasıl şifrelendiğini anlamak veya bir sistemin zafiyetini analiz ederken hangi kriptografik yöntemin yanlış uygulandığını (zayıf anahtar kullanımı, eski algoritmalar vb.) saptamak için bu mantık zincirini kavramak zorundasınız. Sertifika sınavlarında ve gerçek dünya operasyonlarında (Red Teaming/Pentesting) karşınıza çıkacak olan karmaşık protokollerin (HTTPS, SSH, IPsec) tamamı bu temel prensipler üzerine inşa edilmiştir.

Symmetric Encryption: Veriyi Simetrik Anahtarlarla Koruma

Siber güvenliğin en temel problemlerinden biri şudur: İki kişi arasındaki tüm veri akışı üçüncü bir tarafça izlenirken, bu iki kişi nasıl hala gizli bilgi paylaşabilir? Bu sorunun cevabı, veriyi bir "kilitli kutu" içine yerleştirmekten geçer.

Temel Kriptografik Terimler

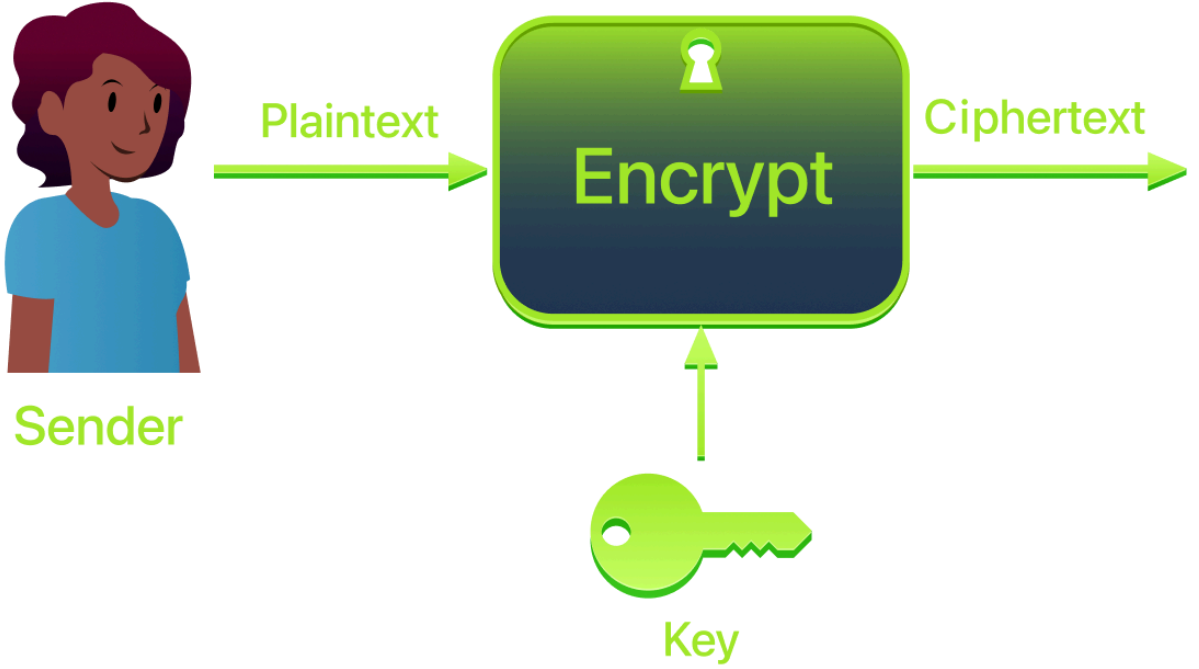
Kriptografi dünyasına adım atarken řu dört kavramı eksiksiz bilmek, süreçlerin mantığını kavramak için şarttır:

- **Plaintext (Açık Metin):** Herkes tarafından okunabilen, ham veri. (Örn: HELLO veya Kullanıcı adı: admin).
- **Ciphertext (Şifreli Metin):** Algoritma ve anahtar kullanılarak karıştırılmış, yetkisiz kişiler için anlamsız olan veri. (Örn: KH00R).
- **Key (Anahtar):** Şifreleme ve çözme işlemini kontrol eden gizli bileşen. Algoritmanın nasıl çalışacağını belirleyen bir "parola" veya "parametre" gibi düşünülebilir.
- **Algorithm (Algoritma):** Verinin nasıl şifreleneceğini belirleyen, herkesçe bilinebilen matematiksel adımlar dizisi (reçete).

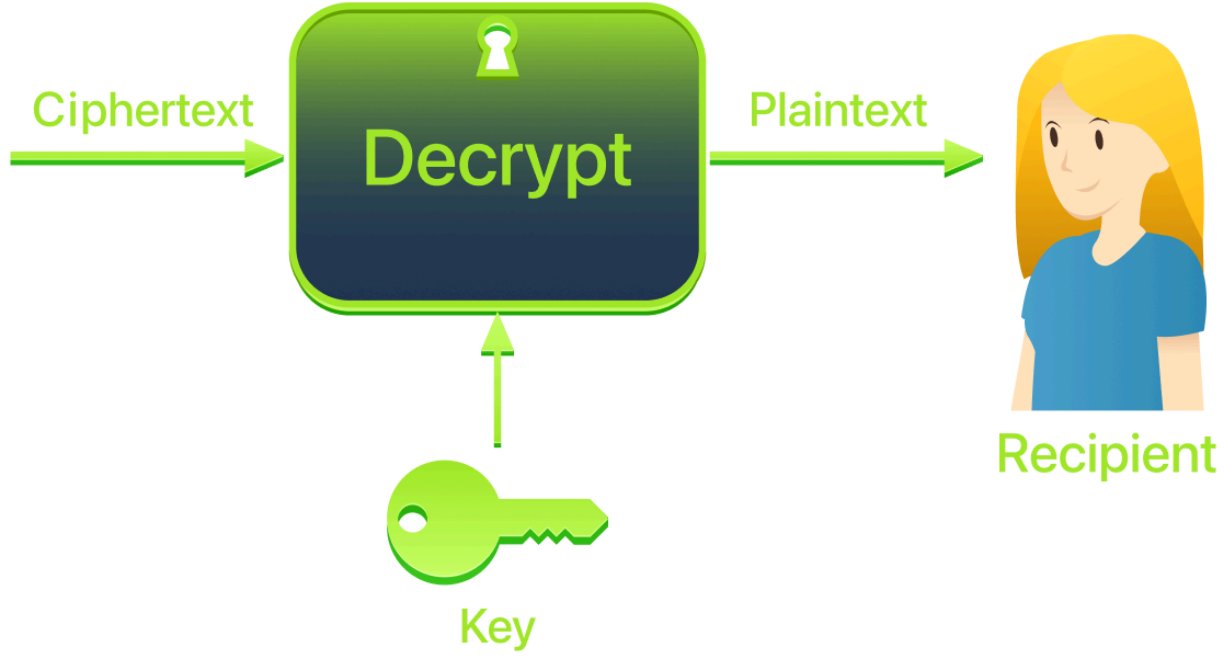
Şifreleme ve Şifre Çözme Mantığı

Kriptografik bir işlem her zaman řu formül üzerinden ilerler:

1. **Encryption (Şifreleme):** plaintext + algorithm + key → ciphertext



1. **Decryption (Şifre Çözme):** ciphertext + algorithm + key → plaintext



Kilitli Kutu Analojisi

Güvenliği sağlamak için algoritmayı (kilidin nasıl çalıştığını) gizlemeye çalışmayız. Modern kriptografide güvenlik, **Kerckhoffs İlkesi** uyarınca algoritmanın değil, **anahtarın (key)** gizli tutulmasına dayanır. Bir posta kutusunun çalışma prensibini herkes bilebilir, ancak sadece doğru anahtara sahip olan içindeki mektuba ulaşabilir.

Caesar Cipher (Sezar Şifrelemesi): Pratik Bir Örnek

Symmetric Encryption'ı anlamak için tarihteki en eski yöntemlerden biri olan **Caesar Cipher**'i inceleyelim. Bu yöntem, alfabedeki her harfin belirli bir sayı kadar kaydırılması esasına dayanır.



Çalışma Mantığı ve Parametreler

- **Algoritma:** Alfabedeki harfleri sabit bir sayı kadar ileri/geri kaydır.
- **Key (Anahtar):** Kaydırma miktarı (Örn: 3).

Örnek Şifreleme (Key = 3):

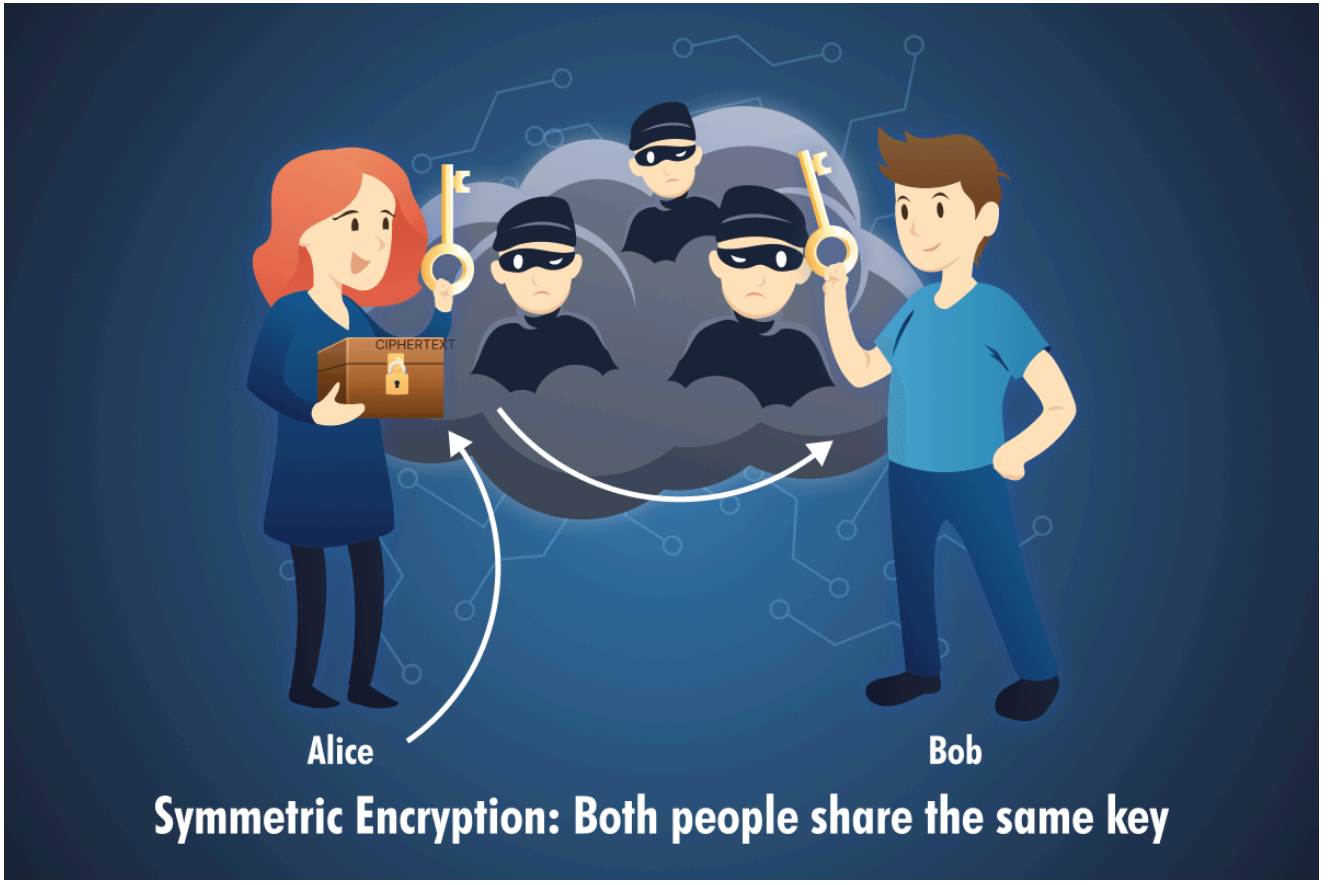
- H → (I, J, K)
- E → (F, G, H)
- L → (M, N, O)
- O → (P, Q, R)
- **Sonuç:** HELLO → KHOOR

Örnek Şifre Çözme (Key = 3): Harfleri alfabede 3 birim geri kaydırıldığınızda orijinal HELLO metnine geri dönülür.

DİKKAT: Caesar Cipher bugün sadece eğitim amaçlı kullanılır. Toplamda sadece 25 olasılık (anahtar) olduğu için bir bilgisayar tarafından milisaniyeler içinde **Brute Force** (Kaba kuvvet saldırısı) ile kırılabilir. Modern sistemlerde bunun yerine **AES (Advanced Encryption Standard)** gibi çok daha karmaşık algoritmalar kullanılır.

Symmetric Encryption (Simetrik Şifreleme) Nedir?

Simetrik şifrelemede, veriyi şifrelemek (kilitlemek) ve şifresini çözmek (açmak) için **aynı anahtar** kullanılır. Hem gönderici hem de alıcı bu gizli anahtarın bir kopyasına sahip olmalıdır.



Avantajları:

- **Hız:** Matematiksel olarak daha az işlem gücü gerektirir, bu yüzden çok hızlıdır.
- **Verimlilik:** Büyük dosyaların, sabit disklerin ve yoğun ağ trafiğinin şifrelenmesi için idealdir.

Dezavantajı: Key Distribution Problem (Anahtar Dağıtım Sorunu)

Simetrik şifrelemenin "topuk noktası" anahtarın güvenli bir şekilde paylaşılmasıdır.

- Eğer Alice, Bob'a anahtarı internet üzerinden açıkça gönderirse, aradaki saldırgan anahtarı ele geçirir.
- Anahtarı ele geçiren biri, o anahtarla yapılan tüm geçmiş ve gelecek iletişimleri deşifre edebilir.
- "Anahtarı da şifreleyip gönderelim" mantığı, "o anahtarı şifreleyen anahtarı nasıl göndereceğiz?" sorusuna (Sonsuz Döngü - Infinite Regress) yol açar.

Teknik Özet ve Uygulama

Symmetric Encryption, hızı nedeniyle vazgeçilmezdir ancak **Key Distribution Problem** nedeniyle tek başına yeterli değildir. Gerçek dünya senaryolarında:

1. Veri simetrik bir anahtarla (hızlı olsun diye) şifrelenir.
2. Bu simetrik anahtar ise **Asymmetric Encryption** (Asimetrik Şifreleme) kullanılarak karşı tarafa güvenli bir şekilde iletilir.

ÖNEMLİ: Siber güvenlikte bir algoritmanın güvenli olup olmadığını belirleyen şey, anahtarın bit uzunluğu ve algoritmanın karmaşıklığıdır. Caesar gibi "Substitution" (Yer değiştirme) tabanlı basit şifreler, frekans analizi gibi yöntemlerle saniyeler içinde çözülebilir. Ancak AES gibi modern standartlar, anahtar bilinmediği sürece günümüz teknolojisiyle kırılmaz kabul edilir.

Asymmetric Encryption: Güvenli Anahtar Dağıtımı ve Sertifika Mimarisi

Anahtar Dağıtım Problemi (The Key Distribution Problem)

Symmetric Encryption (Simetrik Şifreleme - veriyi şifrelemek ve deşifrelemek için aynı gizli anahtarın kullanıldığı yapı) büyük verileri işlerken son derece hızlı ve verimlidir. Ancak bu yapının temel bir zafiyeti vardır: Taraflar ortak gizli anahtarı birbirlerine güvenli bir şekilde nasıl iletecekler?

Eğer anahtar ağ üzerinden plaintext (şifrelenmemiş açık metin) olarak gönderilirse, trafiği dinleyen bir saldırgan (Man-in-the-Middle) anahtarı kolayca ele geçirir. Anahtarı şifreleyerek göndermeye kalkarsak, bu kez şifreleme işlemi için ikinci bir anahtara ihtiyaç duyarız ve bu durum sonsuz bir çıkmaza yol açar. Ağ üzerinde hiçbir zaman gizli bir veriyi doğrudan transfer etmeden iletişimi başlatabilmek için **Asymmetric Encryption** (Asimetrik Şifreleme) mimarisine ihtiyaç duyarız.

Asimetrik Şifreleme Mimarisi ve Anahtar Çiftleri (Key Pairs)

Asymmetric Encryption, matematiksel bir fonksiyonla birbirine sıkı sıkıya bağlı iki farklı anahtardan oluşan bir yapı kullanır:

- **Public Key** (Genel Anahtar): Sistemdeki herkes tarafından bilinebilen, ağ üzerinde açıkça paylaşılmasında hiçbir güvenlik riski bulunmayan anahtardır.
- **Private Key** (Özel Anahtar): Sadece sahibinin bildiği ve kesinlikle gizli tutulması gereken anahtardır.

Bu mimarinin temel mantığı şu kurala dayanır:

Public Key kullanılarak şifrelenmiş bir veri, *sadece ve sadece* o anahtarın eşi olan **Private Key** ile çözülebilir. Diğer senaryoda ise, **Private Key** ile şifrelenen bir veri, herhangi birinin erişebildiği **Public Key** ile çözülebilir (Bu özellik gizlilik sağlamaktan ziyade, verinin kaynağını doğrulamak için kullanılan **Digital Signatures** / Dijital İmzalar konseptinin temelini oluşturur).

ÖNEMLİ: Bu iki anahtar arasındaki matematiksel bağ, tek yönlü fonksiyonlara (örneğin devasa asal sayıların çarpanlarına ayrılması veya eliptik eğriler) dayanır. Bir bilgisayarın **Public Key**'i analiz ederek eşi olan **Private Key**'i tersine mühendislikle (reverse engineering) bulması günümüz teknolojisiyle yüzlerce, hatta binlerce yıl sürer. Asimetrik şifrelemeyi güvenli kılan yegane unsur bu devasa "hesaplama zorluğudur" (computational difficulty).

İletişim Akışı ve Posta Kutusu Analogisi

Sistemin mimarisini anlamak için sokaktaki standart bir posta kutusunu düşünebiliriz. Posta kutusunun üzerindeki mektup atma yarığı **Public Key**'dir. Yoldan geçen herkes bu yarığı görüp içine mektup bırakabilir; bu işlem tamamen dışarıya açıktır. Ancak posta kutusunun kapağını açan fiziksel anahtar **Private Key**'dir ve sadece kutu sahibinde bulunur.

Ağ üzerinde iki tarafın (Alice ve Bob) iletişim kurma senaryosu:

1. Bob kendi sisteminde bir anahtar çifti oluşturur. **Private Key**'i sisteminde güvenli bir şekilde saklar, **Public Key**'i ise internet ortamında (web sitesinde veya bir anahtar sunucusunda) açıkça yayımlar.
2. Alice, Bob'a gizli bir mesaj göndermek istediğinde Bob'un **Public Key**'ini elde eder.
3. Alice, hazırladığı veri paketini (Payload) Bob'un **Public Key**'i ile şifreler (Encrypt) ve ağ üzerinden Bob'a gönderir.
4. Ağ trafiğini izleyen bir saldırgan bu paketi yakalasa dahi, paketi deşifre edecek matematiksel yeteneğe sahip değildir.
5. Bob paketi alır ve *sadece kendisinde bulunan* **Private Key** ile veriyi deşifre eder (Decrypt).

Bu akış sayesinde ağ üzerinden gizli hiçbir anahtar değişimi yapılmamıştır. Hedefe ulaşan tek anahtar, tasarım gereği gizli olmayan **Public Key**'dir.

Gerçek Dünya Entegrasyonu: HTTPS ve Hybrid Approach (Hibrit Yaklaşım)

Asymmetric Encryption, güvenli anahtar değişimi için kusursuzdur ancak yoğun işlem gücü gerektirdiği için büyük boyutlu veri transferlerinde **çok yavaştır**. Bu nedenle günümüz HTTPS mimarisi, VPN'ler ve uçtan uca şifreli mesajlaşma uygulamaları her iki algoritmanın avantajlarını kullanan **Hybrid Approach** (Hibrit Yaklaşım) kullanır.

Tarayıcınız üzerinden <https://google.com> adresine bağlandığınızda arka planda şu teknik adımlar gerçekleşir:

1. İstemci (Browser), sunucuya (Server) bağlanır ve sunucunun **Public Key**'ini talep eder.
2. Sunucu, kendi **Public Key**'ini barındıran bir **Certificate** (Sertifika) paketini istemciye gönderir.
3. İstemci ve sunucu, asimetrik şifreleme altyapısını kullanarak, sadece o oturuma özel üretilen rastgele bir gizli anahtar (Shared Secret / Session Key) üzerinde güvenli bir şekilde anlaşırlar.
4. Bu ortak anahtar güvenle oluşturulduktan sonra asimetrik şifreleme devreden çıkar. Oturumun geri kalanındaki tüm veri alışverişi, az önce oluşturulan bu ortak anahtar kullanılarak çok daha performanslı olan **Symmetric Encryption** ile yürütülür.

Kritik Çıkarım: Asimetrik şifreleme, simetrik şifrelemede kullanılacak olan anahtarı güvenli bir şekilde dağıtmak için kapıyı açan bir öncü kuvvettir. Ağır işi (bulk data transfer) simetrik şifreleme üstlenir.

Dijital Sertifikalar (Digital Certificates) ve Güven Zinciri (Chain of Trust)

Anahtar dağıtımındaki en büyük güvenlik riski şudur: İstemcinin aldığı **Public Key**'in gerçekten hedef web sitesine (örneğin bankanıza) ait olduğunu, araya giren ve sahte bir **Public Key** sunan bir saldırgana ait olmadığını nasıl bilebiliriz?

Bu kimlik doğrulama problemini çözmek için **Digital Certificates** ve **Certificate Authority - CA** (Sertifika Otoritesi) mimarisi kullanılır. Sertifika, aşağıdaki kritik bileşenleri barındıran dijital bir dokümandır:

- Hedef kuruluşun **Public Key**'i.
- Bu anahtarın kime (örneğin `example.com` domainine) ait olduğu bilgisi.
- Tüm bu bilgilerin doğruluğunu onaylayan güvenilir bir CA'nin (Sertifika Otoritesi) dijital imzası.

İşletim sistemleri ve modern tarayıcılar (Chrome, Firefox vb.), kök dizinlerinde global düzeyde güvenilir kabul edilen CA'lerin listesini barındırır. Bir sunucu istemciye sertifikasını sunduğunda, tarayıcı şu doğrulama adımlarını uygular:

- Sertifikadaki dijital imza, tarayıcının sisteminde yüklü olan güvenilir bir CA tarafından mı atılmış?
- Sertifikanın geçerlilik süresi (Valid from / Valid until) devam ediyor mu?
- Sertifika, özel anahtarın sızdırılması gibi bir güvenlik ihlali sebebiyle iptal listesine (Revocation List) alınmış mı?

Eğer bu parametrelerin tamamı doğrulanırsa, tarayıcı adres çubuğunda o güven verici "kilit" ikonunu gösterir. Eğer sertifika süresi dolmuşsa veya self-signed (kişinin kendi kendine imzaladığı, otorite onayı olmayan) bir sertifikaysa tarayıcı bağlantıyı keserek kritik bir güvenlik uyarısı verir. Tarayıcıda bir sitenin sertifikasını incelediğimizde gördüğümüz **Issued to** (Kime verildiği), **Issued by** (Kim tarafından imzalandığı) ve geçerlilik tarihleri bu doğrulama mekanizmasının loglarıdır.

Mimarilerin Karşılaştırılması: Simetrik vs. Asimetrik

Teknik Özellik	Symmetric Encryption (Simetrik)	Asymmetric Encryption (Asimetrik)
Anahtar Sayısı	Tek bir anahtar (Hem Encrypt hem Decrypt için)	İki ayrı anahtar (Public ve Private Key)
Anahtar Paylaşımı	Her iki tarafın da aynı gizli anahtara sahip olması ve bunu	Public Key ağ üzerinde açıkça yayınlanır, Private Key asla

Teknik Özellik	Symmetric Encryption (Simetrik)	Asymmetric Encryption (Asimetrik)
	güvenle paylaşması zorunludur.	paylaşılmaz.
Performans (Hız)	Matematiksel işlemleri basit olduğu için son derece hızlıdır. Düşük işlemci gücü tüketir.	Kompleks matematiksel hesaplamalar içerdiği için yavaştır. Sistem kaynaklarını yorar.
Kullanım Senaryosu	Büyük hacimli verilerin (dosyalar, veritabanları, stream edilen ağ trafiği) şifrelenmesi.	Simetrik anahtarların güvenli iletimi (Key Exchange) ve dijital imzalar ile kimlik doğrulama.
Mantıksal Analoji	Bir kasayı kilitlemek ve açmak için kullanılan tek bir fiziksel anahtar.	Sokaktaki bir posta kutusu: Herkes içine belge atabilir, sadece sahibi kilidi açıp okuyabilir.